ONE-PAGE BRIEF

Post-quantum cryptography review: trezor-firmware-en @ 72489948b3c4

Client: SatoshiLabs (Trezor) — public repository (passive review) · Source: github.com/trezor/trezor-firmware, commit `72489948b3c4` · Reviewed: 2026-11-04 19:34 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 3 of 4
hybrid protection in a critical path

FINDINGS
0 Critical **0** High **11** Medium
0 Low **0** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Cover the remaining classical critical roles and plan when the classical half can be dropped.

WHAT MATTERS MOST

Medium QSI-2026-12887	**Transaction signing for 11 chain(s) relies on elliptic-curve signatures** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...
Medium QSI-2026-12877	**Quantum-vulnerable Ed25519: firmware and boot verification (root of trust) (2 file(s))** confirmed by the analyst What to do: Plan a hybrid firmware signature (the classical one plus ML-DSA or SLH-DSA, both required) and the path to ship the new keys in a...
Medium QSI-2026-12879	**Quantum-vulnerable X25519: channel key exchange (TLS, Noise, handshakes) (3 file(s))** confirmed by the analyst What to do: Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols).
Medium QSI-2026-12880	**Quantum-vulnerable ECDSA: transaction and message signing (4 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...

7 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium firmware and boot verification (root of trust)	Ed25519	Plan a hybrid firmware signature (the classical one plus ML-DSA or SLH-DSA, both required) and the path to...
Medium channel key exchange (TLS, Noise, handshakes)	X25519	Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols)
Medium transaction and message signing	ECDSA, Ed25519, Schnorr (BIP-340)	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium authentication and identity (certificates, tokens, device attestation)	ECDSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them

Analyst review: 11 confirmed, 0 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-28)

Static review of source code and manifests; files analysed: 411. No requests were sent to the owner's systems.

Full report, content SHA-256: `90dd7412a16c9c32e0ab86bd7ea84f18277cb6f27e0cc88c4eafa5a87e5841cc`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.